

Corporate Computer Security,
Randall J. Boyle & Raymond R. Panko

Secure Networks

Chapter 4

Learning Objectives

- **Describe the goals of creating secure networks.**
 - **Explain how denial-of-service (DoS) attacks work.**
 - **Know why access controls are important for networks.**
 - **Explain how to secure Ethernet networks.**
 - **Describe wireless (WLAN) security standards.**
 - **Describe potential attacks against wireless networks.**
-

Shingeki no Kyojin, Attack on Titan Wall



Kingdom walls

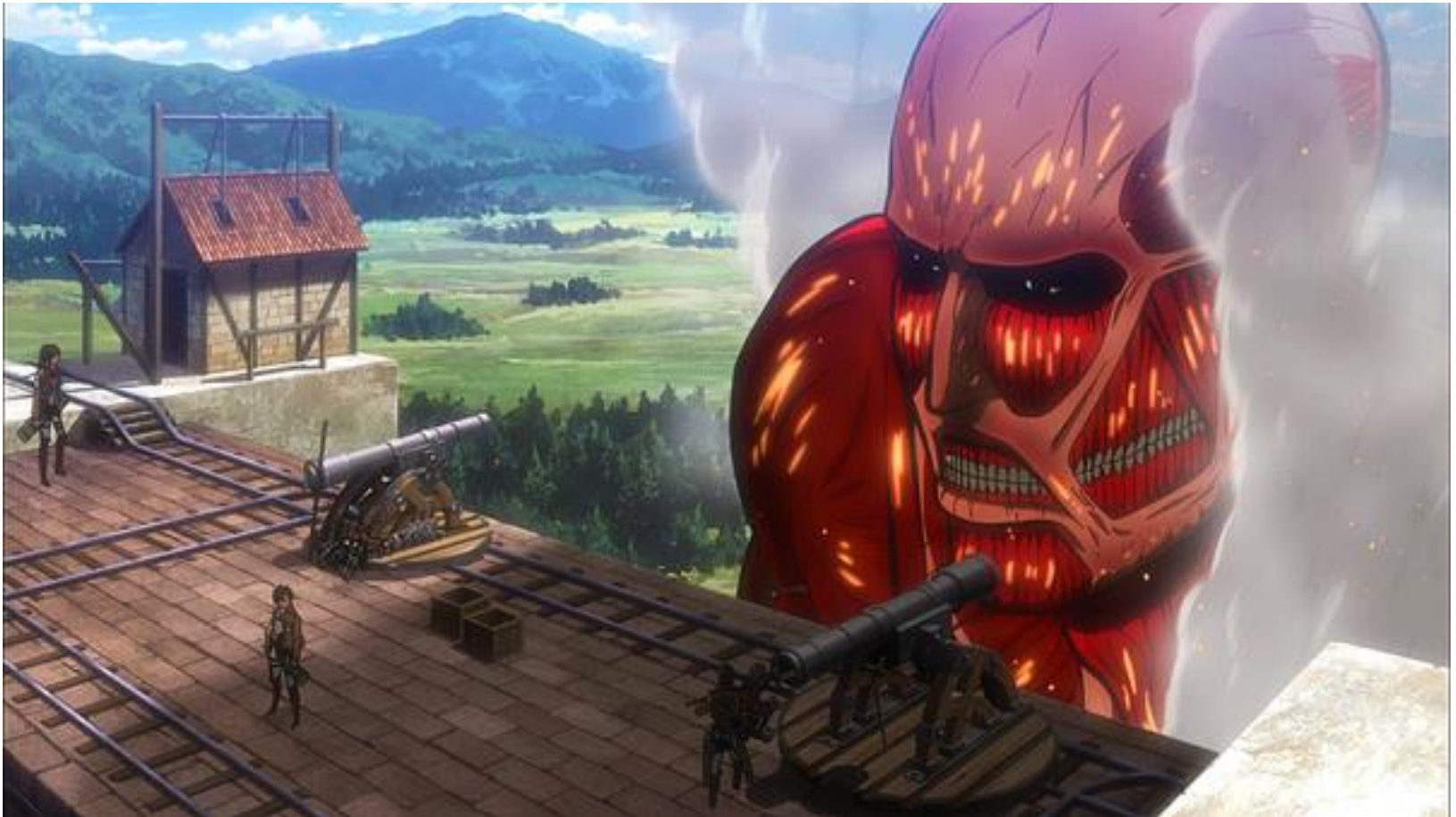
- **Wall Maria**
 - Height 50 m, radius of 480km.
 - Between Wall Maria and Wall Rose is 100km.
 - 100 year period of peace
- **Wall Rose**
 - radius of 380 km
 - Between Wall Rose and Wall Sina is 130 km.
- **Wall Sina**
 - radius of 250 km
 - The safest place within the Kingdom
 - The King resides.

Size of Typical Titan

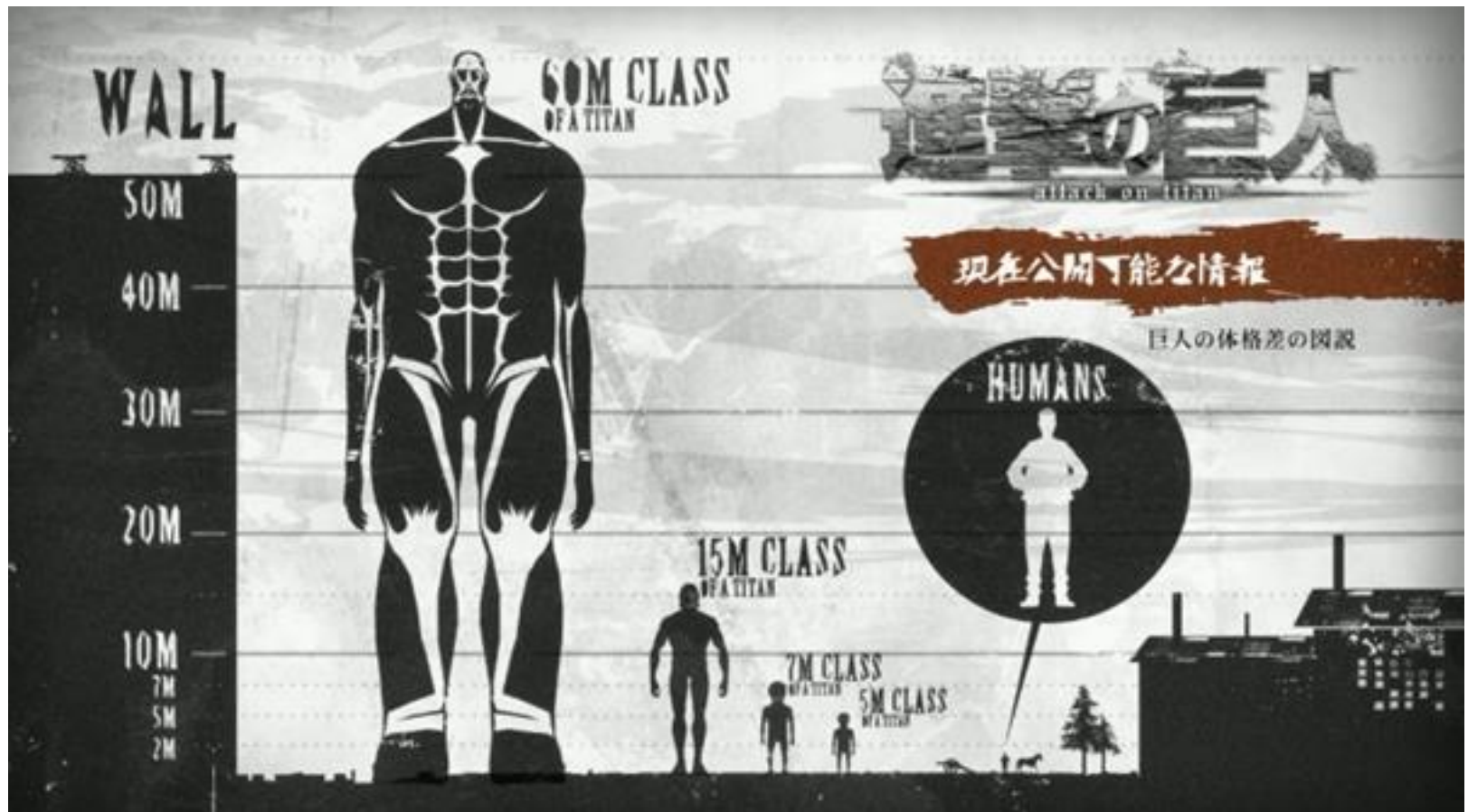
- 3-6 m
- 7 m
- 15 m

Colossal Titan

>50 m

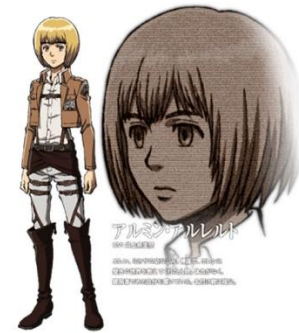


Titan Class

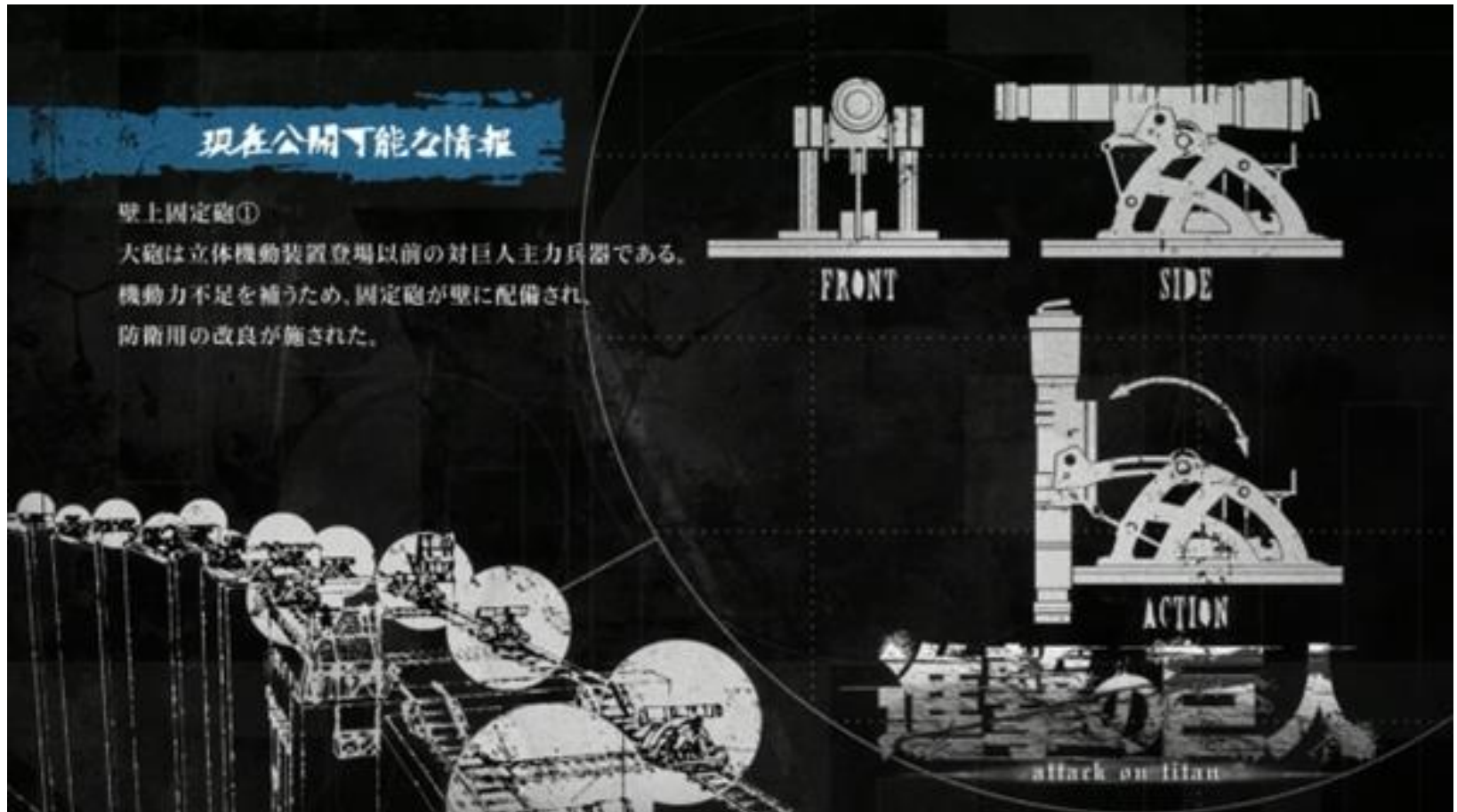


Wall





Weapon



4.1: Threats to Secure Networks

- Cryptography provides confidentiality, authenticity, and message integrity
 - Modern Networks have additional vulnerabilities
 - The *means* of delivering the messages could be stopped, slowed, or altered
 - The *route* the messages took could be altered
 - Messages could be *redirected* to false recipients
 - Attackers could gain *access* to communication channels that were previously considered closed and confidential
-

Primary Goals in Providing Security: “CIA”

- **Confidentiality**
 - Protection of data from unauthorized disclosure of customers and proprietary data
- **Integrity**
 - Assurance that data have not been altered or destroyed
- **Availability**
 - Providing continuous operations of hardware and software so that parties involved can be assured of uninterrupted service

4.1: Creating Secure Networks

Goals of Creating Secure Networks

- 1. Availability—users have access to information services and network resources**
 - 2. Confidentiality—prevent unauthorized users from gaining information about the network**
 - 3. Functionality—preventing attackers from altering the capabilities or normal operation of the network**
 - 4. Access control—keep attackers or unauthorized employees from accessing internal resources**
-

4.2: Denial of Service (DoS) Attacks

- **What is a DoS attack?**
 - An attempt to make a server or network unavailable to legitimate users by flooding it with attack packets
 - **What is NOT a DoS attack?**
 - Faulty coding that causes a system to fail
 - Referrals from large websites that overwhelm smaller websites
-

4.2: Goals of DoS Attacks

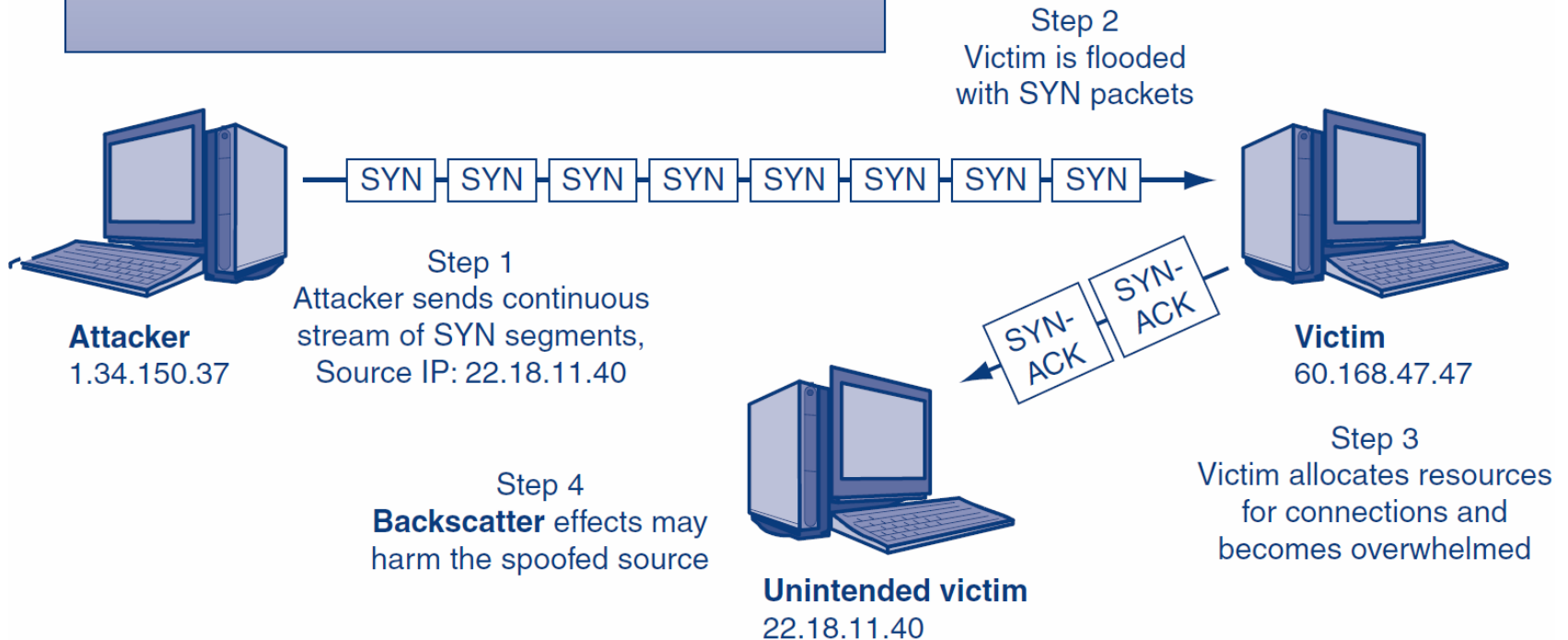
- **Ultimate goal of DoS attacks is to cause harm**
 - **Harm includes: losses related to online sales, industry reputation, employee productivity, customer loyalty, etc.**
 - **The two primary means of causing harm via DoS attacks include:**
 - 1. Stopping critical services**
 - 2. Slowly degrading services**
-

4.2: Methods of DoS Attacks

- **Direct DoS Attack**
 - An attacker tries to flood a victim with a stream of packets directly from the attacker's computer
 - **Indirect DoS Attack**
 - The attacker's IP address is spoofed (i.e., faked) and the attack appears to come from another computer
-

4.2: SYN Flood DoS Attack

Attacker's IP address may be known or spoofed
Attacker cannot see SYN-ACK responses if the source IP address is spoofed
Attacker must have *more resources* than victim
Victim's *network* is also clogged with SYN traffic
Backscatter effects from victim can crash bots too

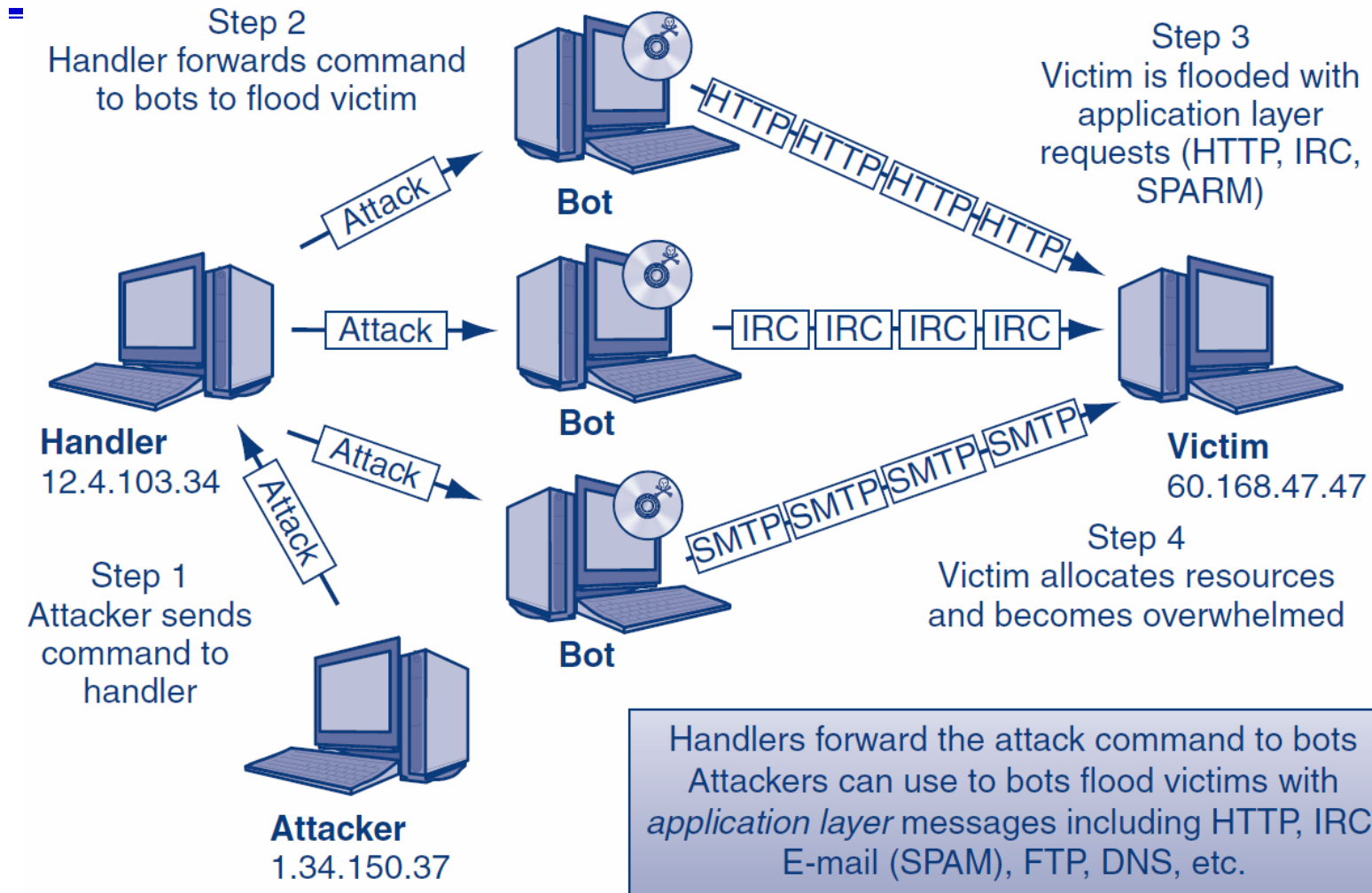


4.2: Types of DoS Packets Sent

- Types of packets sent:

Name		Description
TCP SYN	Transmission Control Protocol Synchronize	Guarantees delivery of packets over the Internet First part of a three-way TCP handshake to make a network connection
SYN-ACK	Synchronize-Acknowledge	Second part of a three-way TCP handshake sent in response to a SYN
ICMP	Internet Control Message Protocol	Supervisory protocol used to send error messages between computers
HTTP	Hypertext Transfer Protocol	Protocol for sending data over the Web

4.2: DDoS Attack



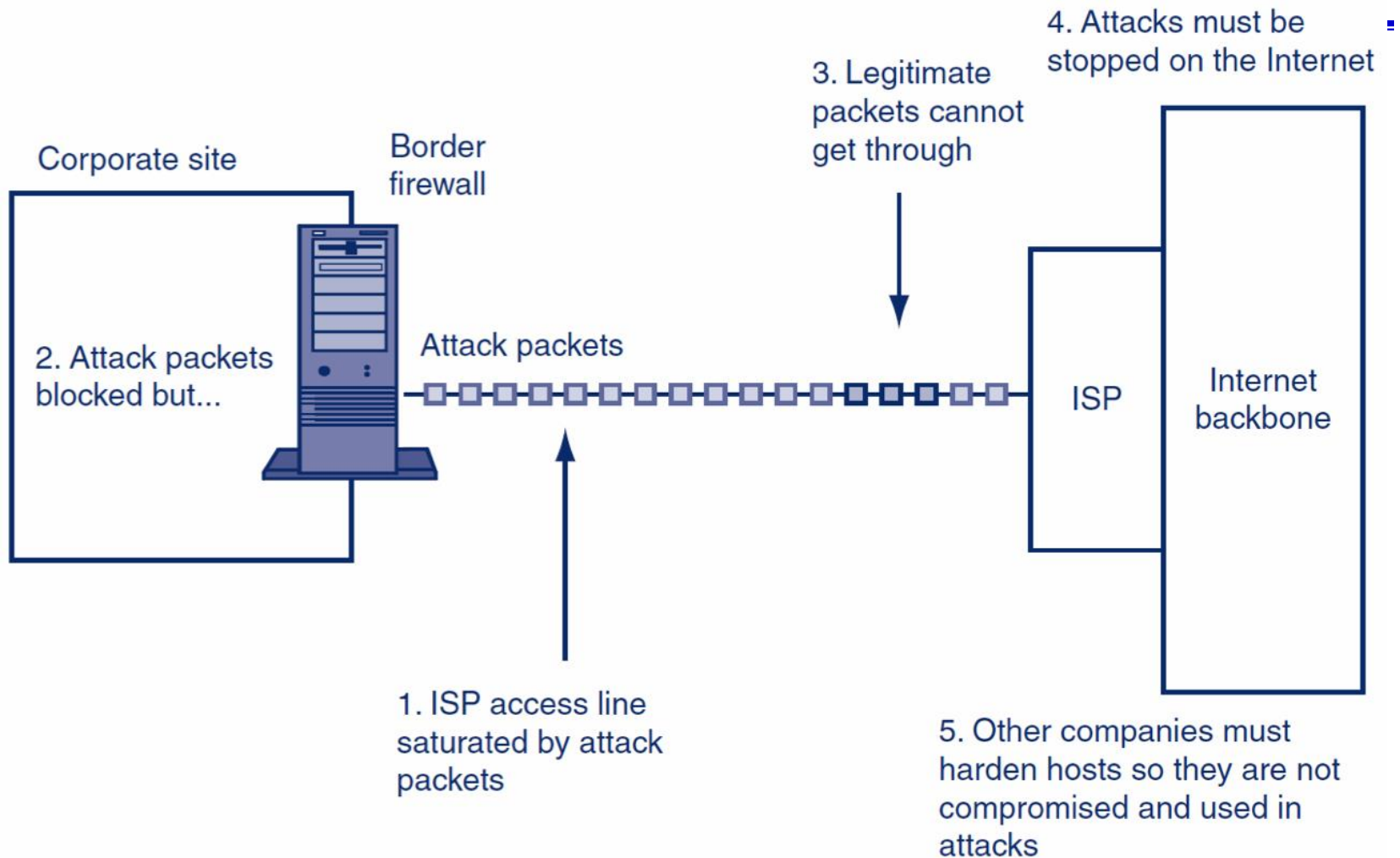
4.2: Defending Against DoS Attacks

- **Black holing**
 - Drop all IP packets from an attacker
 - Not a good long-term strategy because attackers can quickly change source IP addresses
 - An attacker may knowingly try to get a trusted corporate partner black holed
-

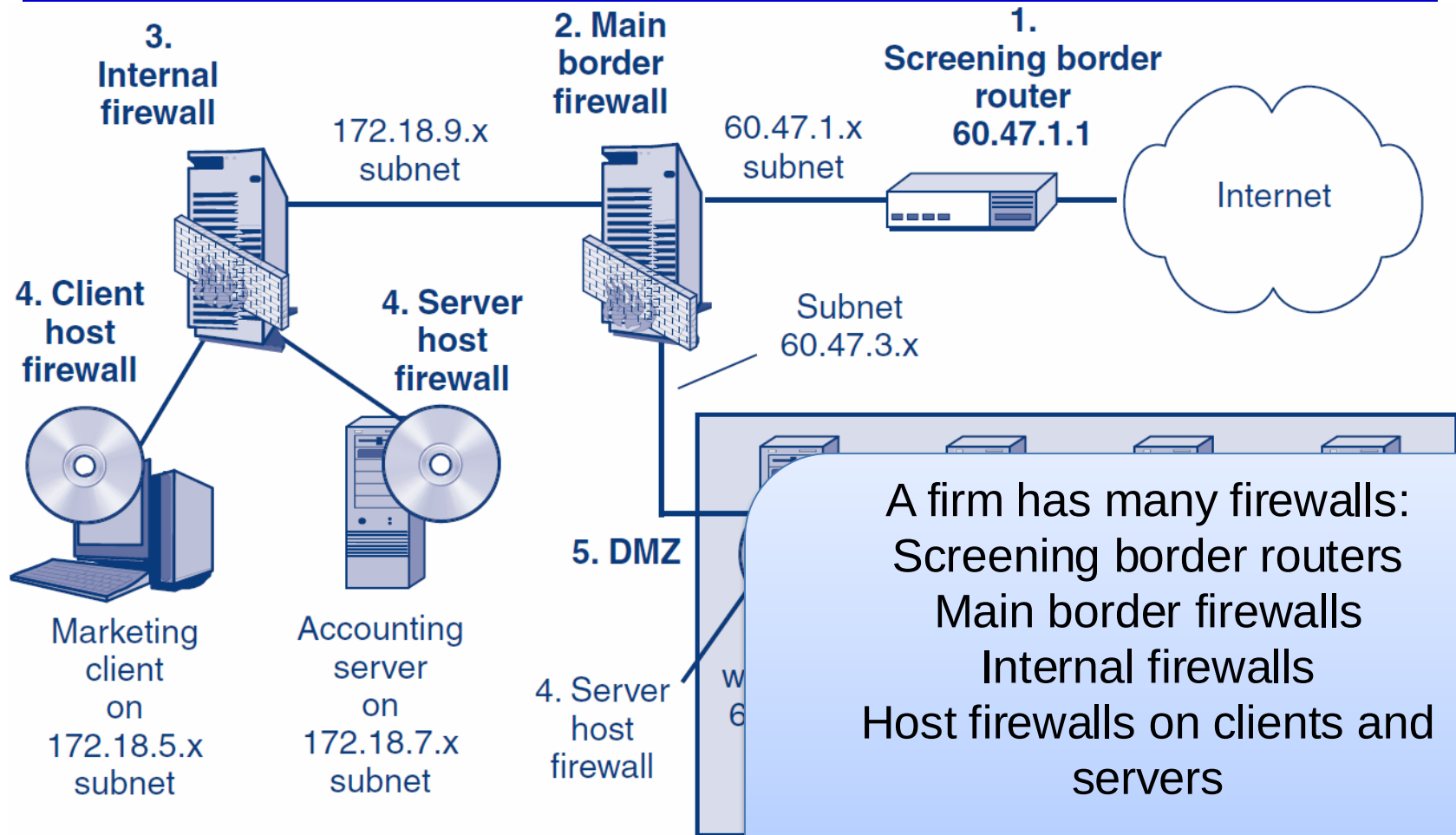
4.2: Defending Against DoS Attacks

- **Validating the handshake**
 - Whenever a SYN segment arrives, the firewall itself sends back a SYN/ACK segment, without passing the SYN segment on to the target server
 - When the firewall gets a legitimate ACK back, the firewall sends the original SYN segment on to the intended server
 - **Rate limiting**
 - Used to reduce a certain type of traffic to a reasonable amount
 - Can frustrate attackers and legitimate users
-

4.2: Stopping DoS Attacks



Firewall Architecture



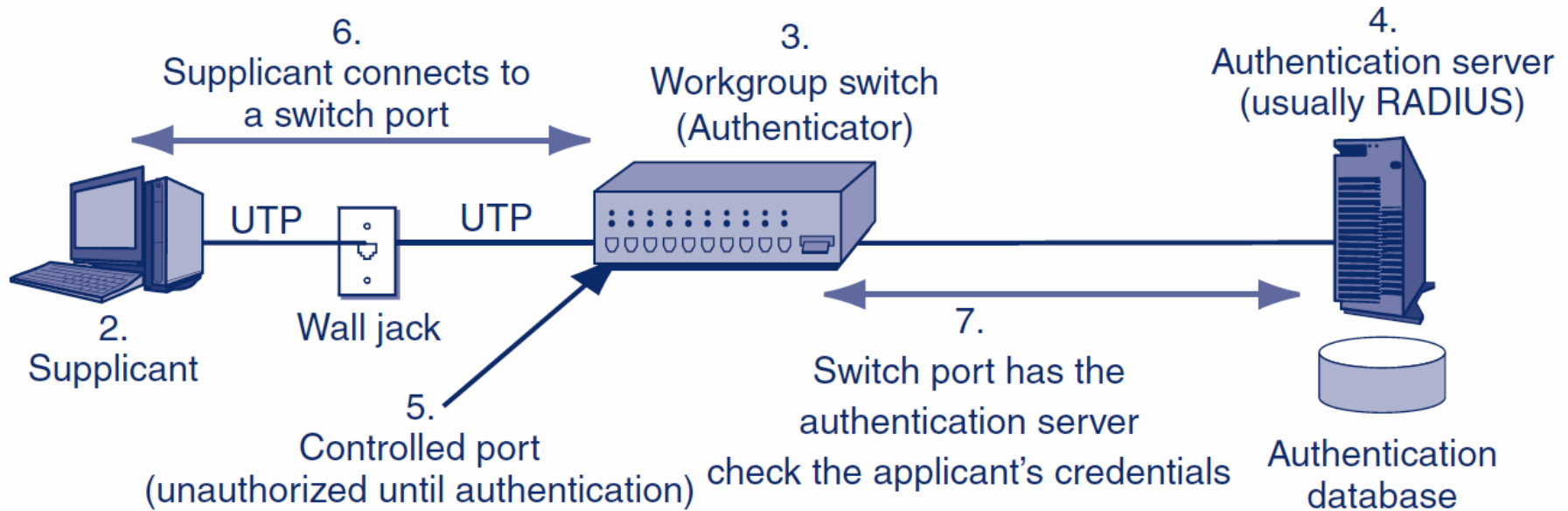
A firm has many firewalls:
Screening border routers
Main border firewalls
Internal firewalls
Host firewalls on clients and servers

The firewall architecture describes how these firewalls work together.

4.5: Ethernet and 802.1X

1.

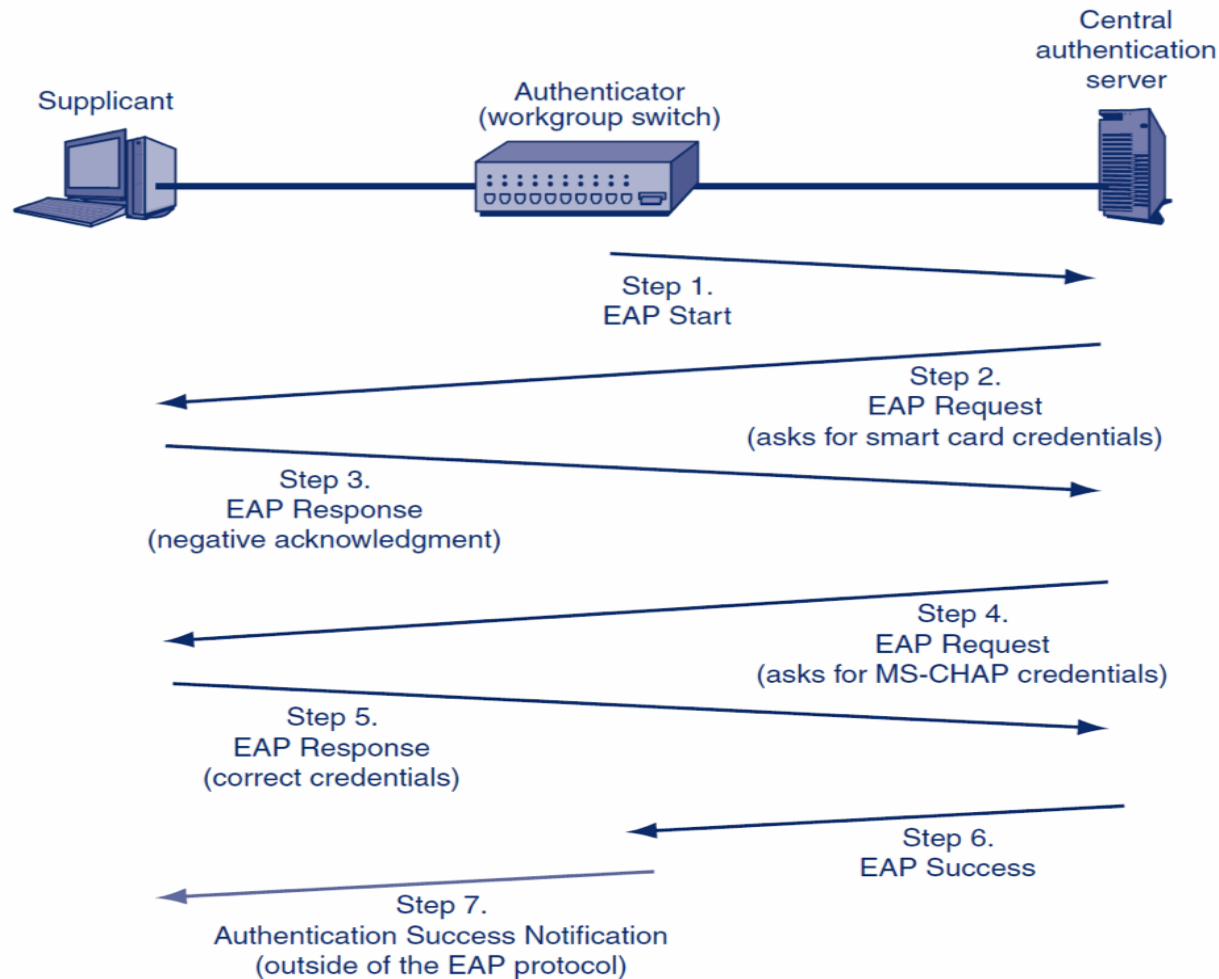
Attacker can walk up to any wall jack and connect to the network, bypassing the border firewall.
802.1X requires the supplicant to authenticate itself before giving entry to the network.



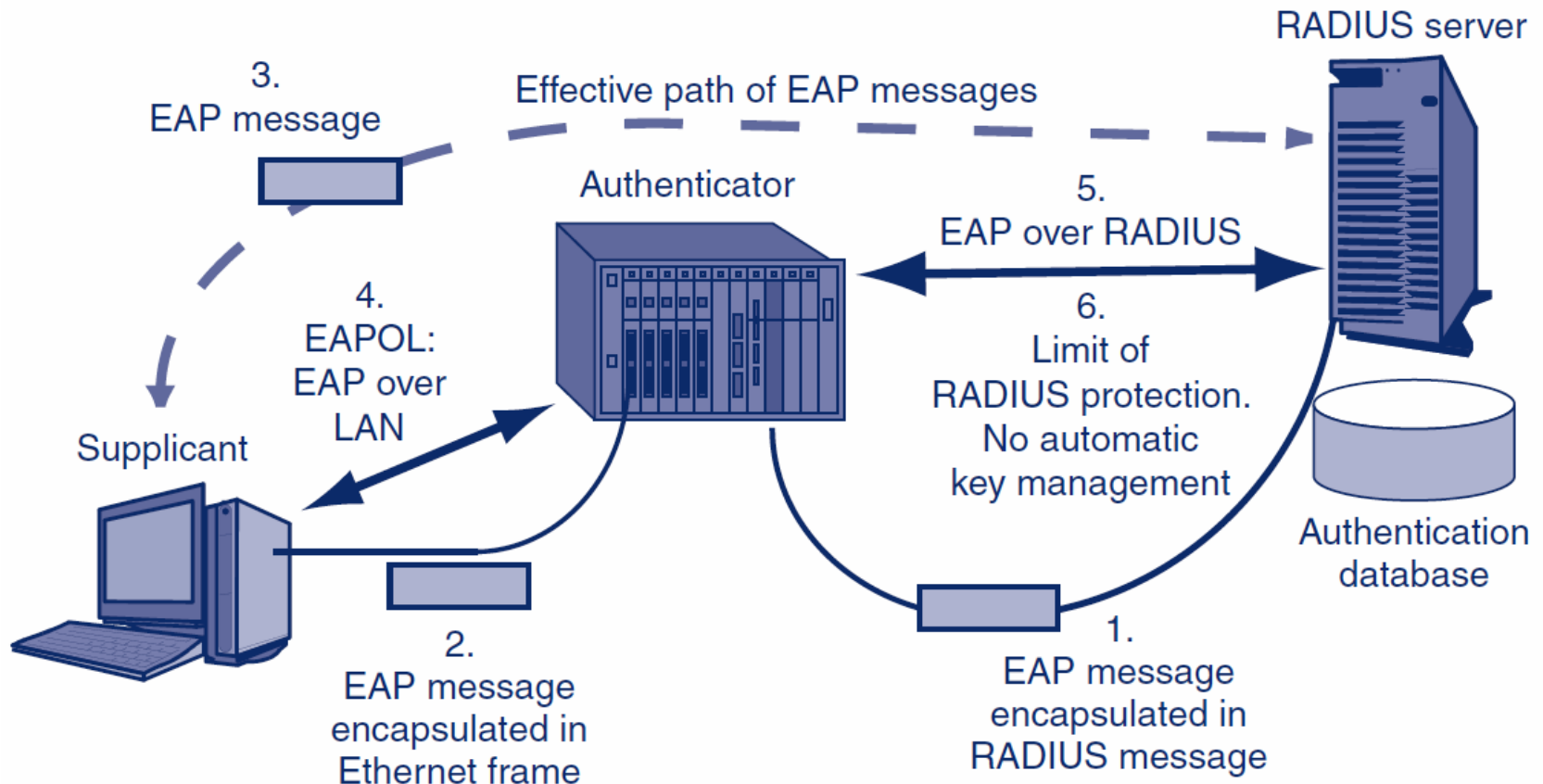
8.

Use of a central authentication server reduces the cost per switch, brings consistency of authentication, and allows immediate changes to authentication data.

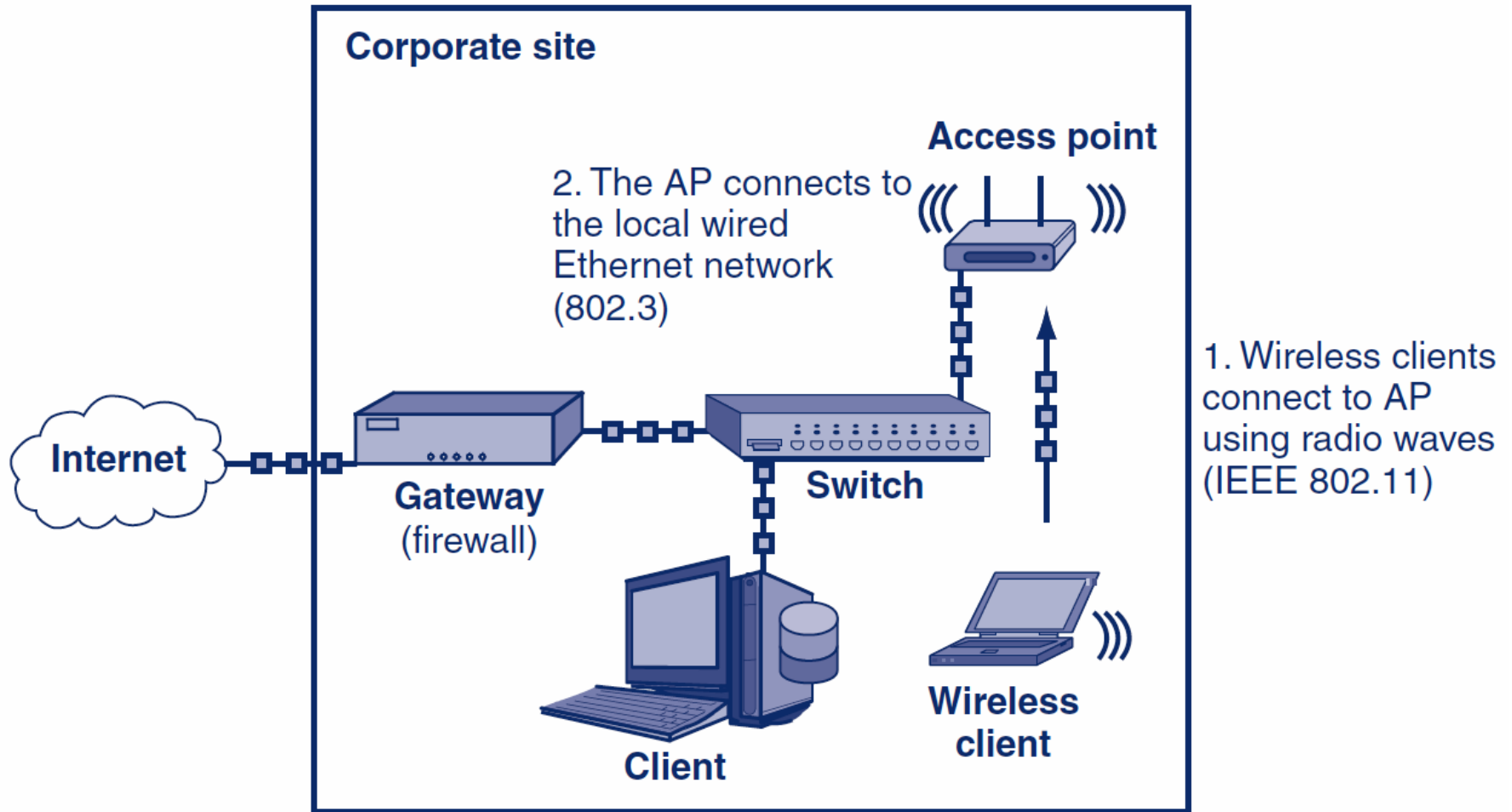
4.5: Extensible Authentication Protocol (EAP)



4.5: EAPOL and EAP over RADIUS



4.6: Wireless Network Access

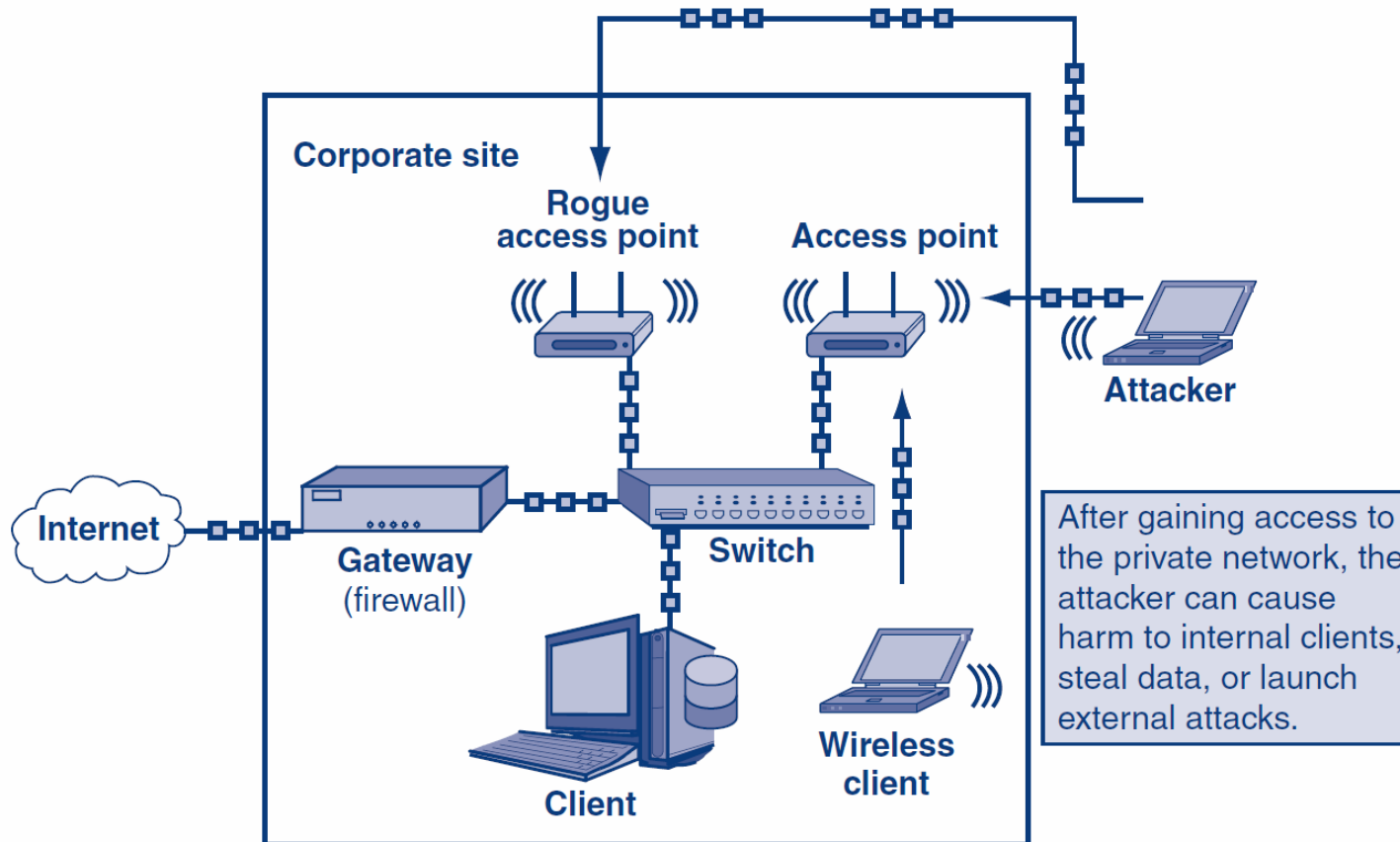


4.6: Unauthorized Network Access

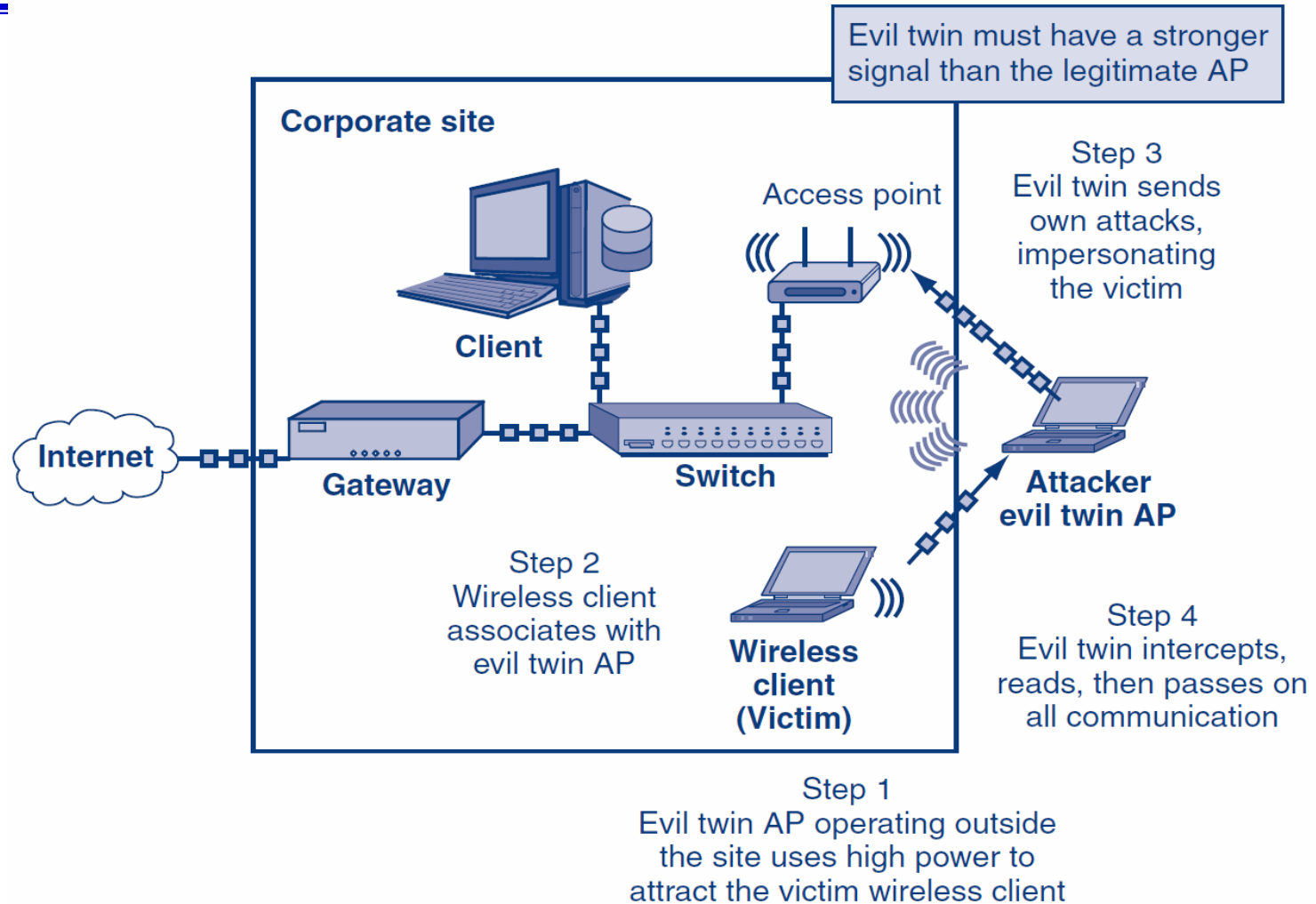
- *Open networks* can be legally accessed by anyone
 - Found in public places like cafés, coffee shops, universities, etc.
 - *Secured networks* have security protocols enabled
 - Users are authenticated and wireless traffic is encrypted
-

4.6: Unauthorized Wireless Access

1. Range of wireless AP is outside the boundaries of the corporate site

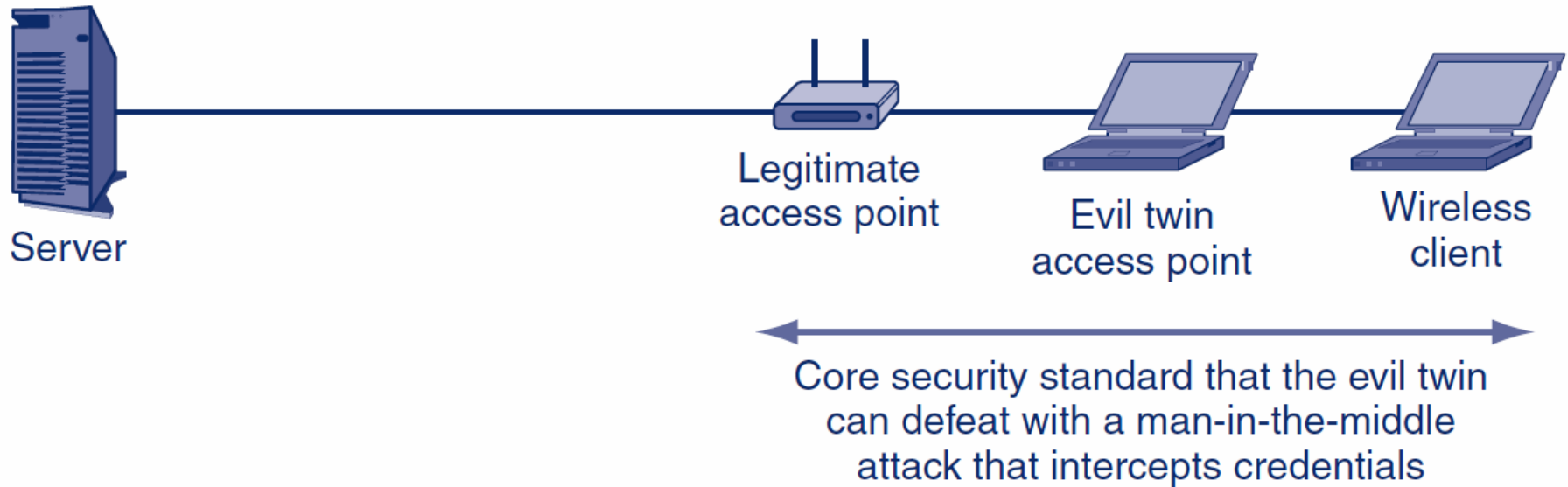


4.6: Evil Twin Access Point

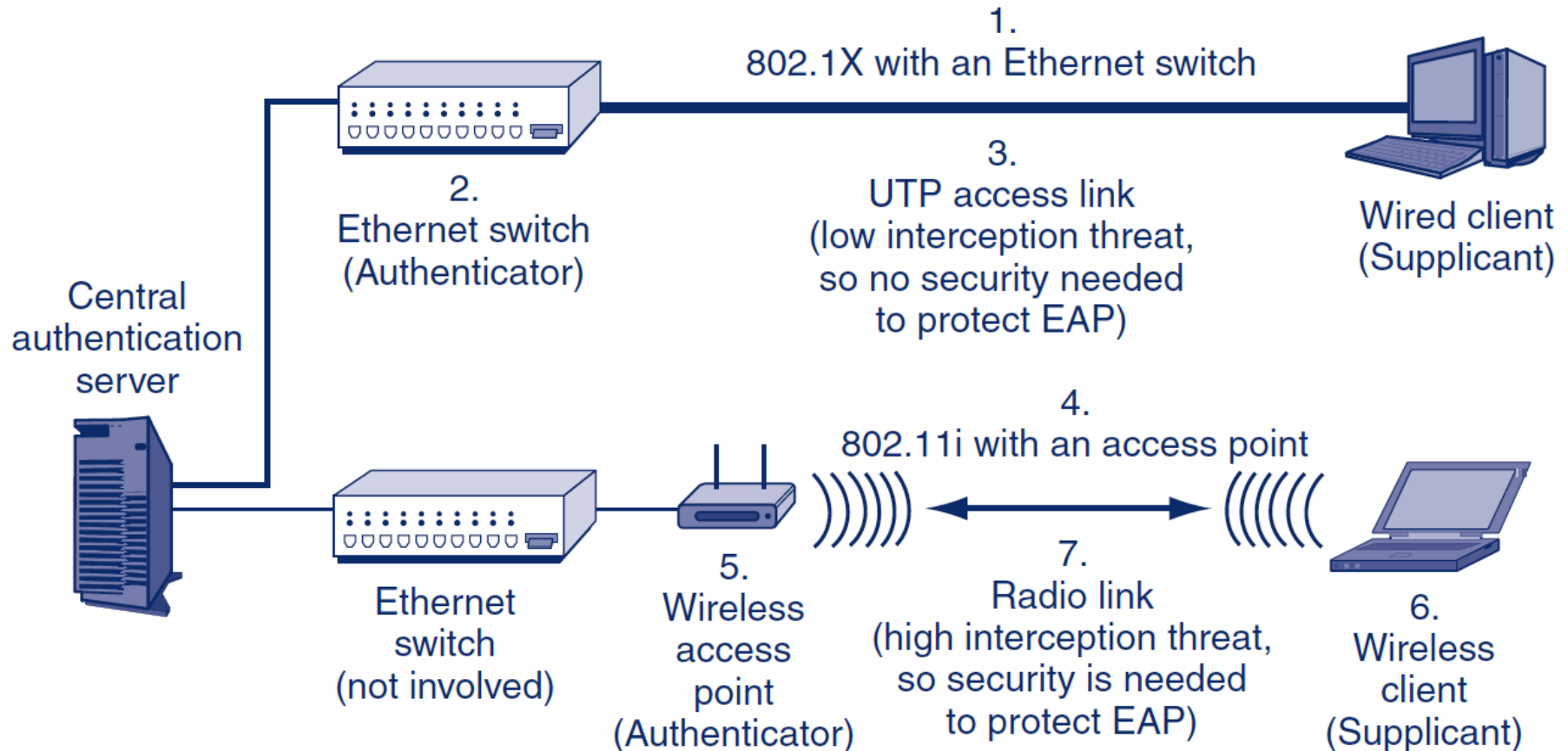


4.6: VPN Protection Against Evil Twin APs

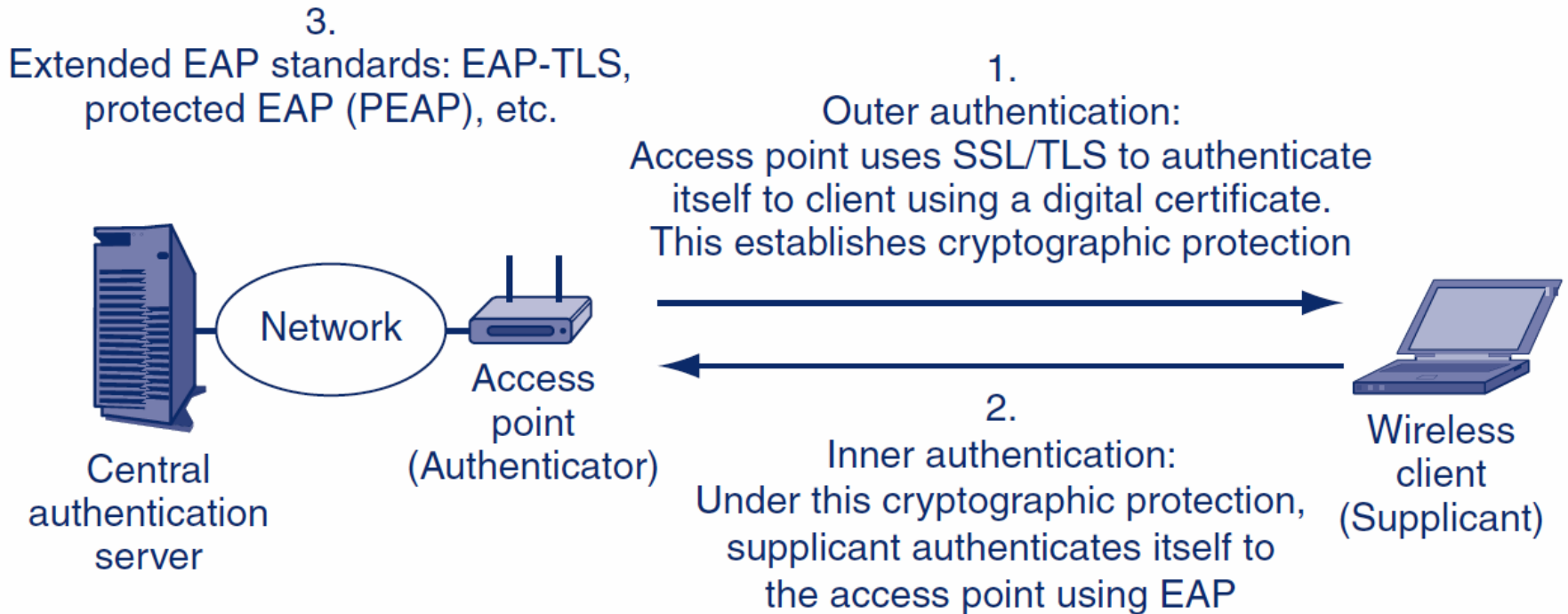
VPN provides end-to-end protection
with a pre-shared secret the evil twin cannot intercept



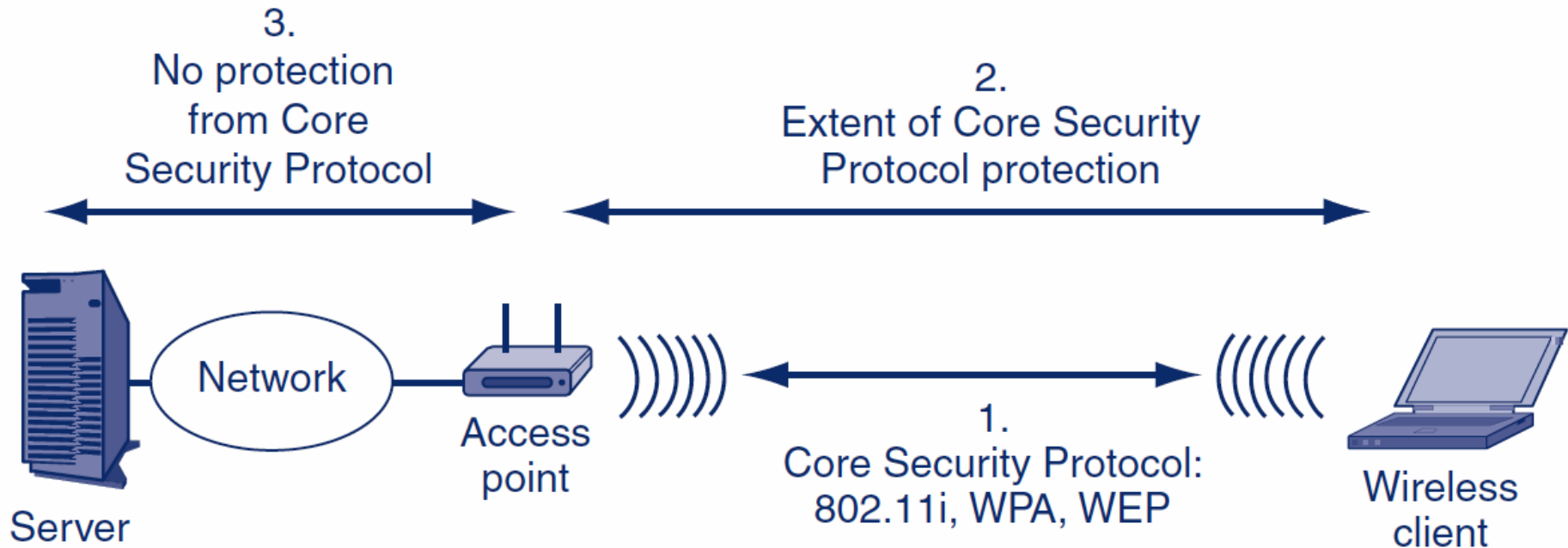
4.6: 802.11i or WPA Wireless LAN Access Control in 802.1X Mode



4.6: Extended EAP Protocols



4.6: 802.11 Core Security Protocol



4.6: Wired Equivalent Privacy (WEP)

- **Origin of WEP**
 - Original core security standard 802.11, created in 1997. However, it became obvious that WEP was fatally flawed.
 - **Uses a Shared Key**
 - Each station using the access point uses the same (shared) key
 - The key is supposed to be secret, so knowing it “authenticates” the user
 - All encryption uses this key
-

4.6: Wired Equivalent Privacy (WEP)

- **Problem with Shared Keys**
 - If the shared key is learned, an attacker near an access point can read *all* traffic
 - Shared keys should be changed frequently
 - WEP had no way to do automatic rekeying
 - Manual rekeying is expensive if there are many users
 - Manual rekeying is operationally next to impossible if many or all stations use the same shared key, because of the work involved in rekeying many or all corporate clients
-

4.6: Wired Equivalent Privacy (WEP)

- **Problem with Shared Keys**
 - Because “everybody knows” the key, employees often give it out to strangers
 - If a dangerous employee is fired, the necessary rekeying may be impossible or close to it
-

4.6: Wired Equivalent Privacy (WEP)

- RC4 Initialization Vectors (IV)
 - WEP uses RC4 for fast and therefore cheap encryption
 - If two frames encrypted with the same RC4 key are compared, the attacker can learn the key
 - To solve this, WEP encrypts with a *per-frame key*, which is the shared WEP key *plus* an 24-bit initialization vector (IV) which is different for each frame.
-

4.6: Wired Equivalent Privacy (WEP)

- However, initialization vector (IV) is randomly generated but it is sent in clear, so many encrypted frames “leak” a few bits of the key
 - With high traffic, an attacker using readily available software can crack a shared key in two or three minutes
-
- **Conclusion**
 - Corporations should never use WEP for security
-

4.6: Wi-Fi Protected Access (WPA)

- **WPA**
 - WPA extends the security of RC4 primarily by increasing the IV from 24 bits to 48 bits
 - This extension vastly reduces leakage and so makes RC4 much harder to crack
 - **WPA2 (802.11i)**
 - 802.11 Working Group completed the 802.11i standard (WPA2) in 2002
 - Uses stronger security methods
-

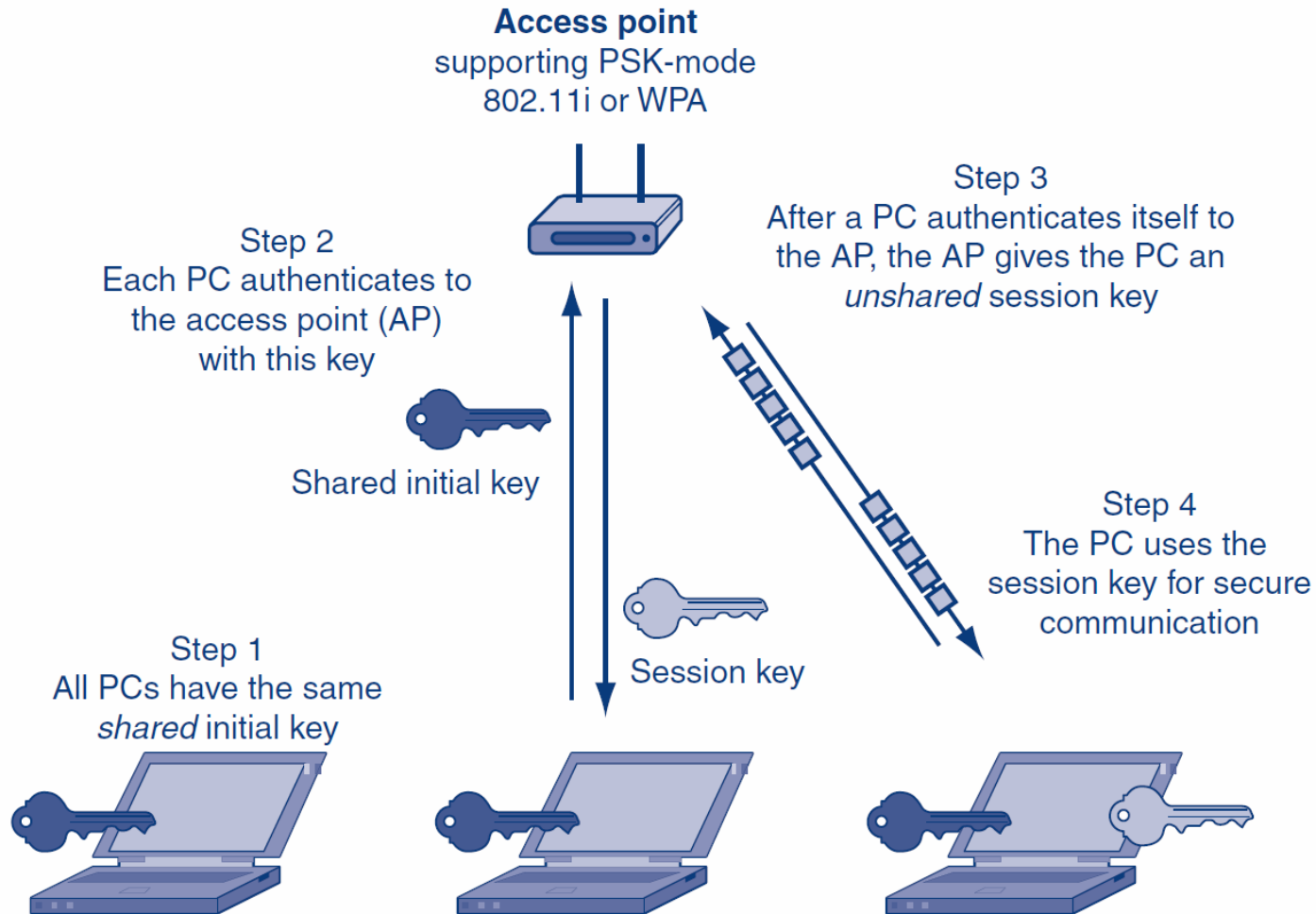
4.6: 802.11

Cryptographic Characteristic	WEP	WPA	802.11i (WPA2)
Cipher for Confidentiality	RC4 with a flawed implementation	RC4 with 48-bit initialization vector (IV)	AES with 128-bit keys
Automatic Rekeying	None	Temporal Key Integrity Protocol (TKIP), which has been partially cracked	AES-CCMP Mode
Overall Cryptographic Strength	Negligible	Weaker, but no complete crack to date	Extremely strong

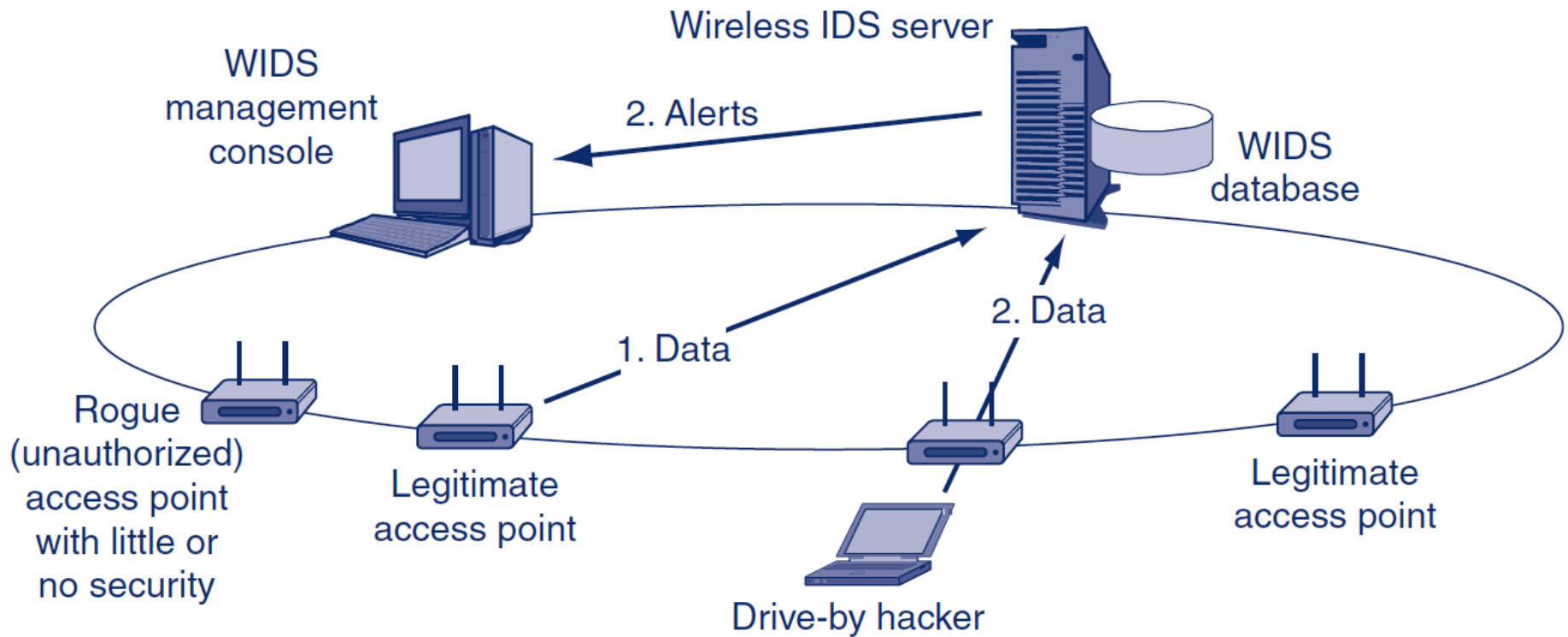
4.6: 802.11

Cryptographic Characteristic	WEP	WPA	802.11i (WPA2)
Operates in 802.1X (Enterprise) Mode?	No	Yes	Yes
Operates in Pre-Shared Key (Personal) Mode?	No	Yes	Yes

4.6: Pre-Shared Key (PSK)/Personal Mode for 802.11i and WPA



4.6: Centralized Wireless Intrusion Detection System



4.6: False 802.11 Security

- **Spread Spectrum Operation and Security**
 - Signal is spread over a wide range of frequencies
 - NOT done for security, as in military spread spectrum transmission
-

4.6: False 802.11 Security

- **Turning Off SSID Broadcasting**
 - **Service set identifier (SSID) is an identifier for an access point**
 - **Users must know the SSID to use the access point**
 - **Drive-by hacker needs to know the SSID to break in**
 - **Access points frequently broadcast their SSIDs**
-

4.6: False 802.11 Security

- **Turning off SSID Broadcasting**
 - **Some writers favor turning off of this broadcasting**
 - **Turning off SSID broadcasting can make access more difficult for ordinary users**
 - **Will not deter the attacker because he or she can read the SSID that transmitted in the clear in each transmitted frame**
-

4.6: False 802.11 Security

- **MAC Access Control Lists**
 - Access points can be configured with MAC access control lists
 - Only permit access by stations with NICs having MAC addresses on the list
 - However, MAC addresses are sent in the clear in frames, so attackers can learn them
 - Attacker can then spoof one of these addresses
-

4.6: False 802.11 Security

- **Perspective**
 - These “false” methods, however, may be sufficient to keep out nosy neighbors
 - Drive-by hackers hit even residential users
 - Simply applying WPA or 802.11i provides much stronger security and is easier to do
-

IP Security

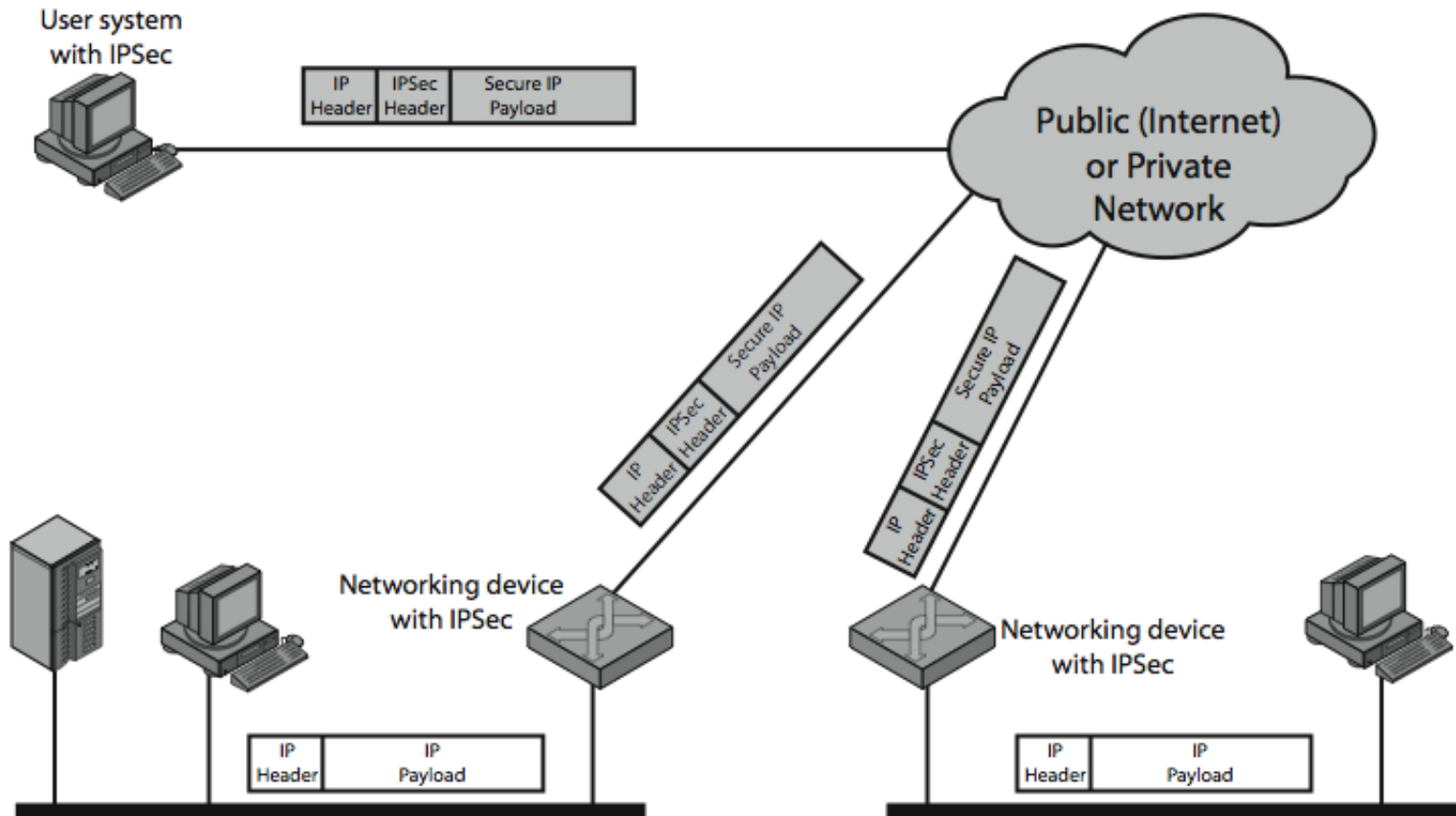
IP Security

- **have a range of application specific security mechanisms**
 - eg. S/MIME, PGP, Kerberos, SSL/HTTPS
- **would like security implemented by the network for all applications**

IPSec

- **general IP Security mechanisms**
- **provides**
 - authentication
 - confidentiality
 - key management
- **applicable to use over LANs, across public & private WANs, & for the Internet**

IPSec Uses



Benefits of IPSec

- **in a firewall/router provides strong security to all traffic crossing the perimeter**
- **in a firewall/router is resistant to bypass**
- **is below transport layer, hence transparent to applications**
- **can be transparent to end users**
- **can provide security for individual users**
- **secures routing architecture**

IP Security Architecture

- **specification is quite complex**
- **defined in numerous RFC's**
 - incl. RFC 2401/2402/2406/2408
 - many others, grouped by category
- **mandatory in IPv6, optional in IPv4**
- **have two security header extensions:**
 - **Authentication Header (AH)**
 - **Encapsulating Security Payload (ESP)**

IPSec Services

- **Access control**
- **Connectionless integrity**
- **Data origin authentication**
- **Rejection of replayed packets**
 - a form of partial sequence integrity
- **Confidentiality (encryption)**
- **Limited traffic flow confidentiality**

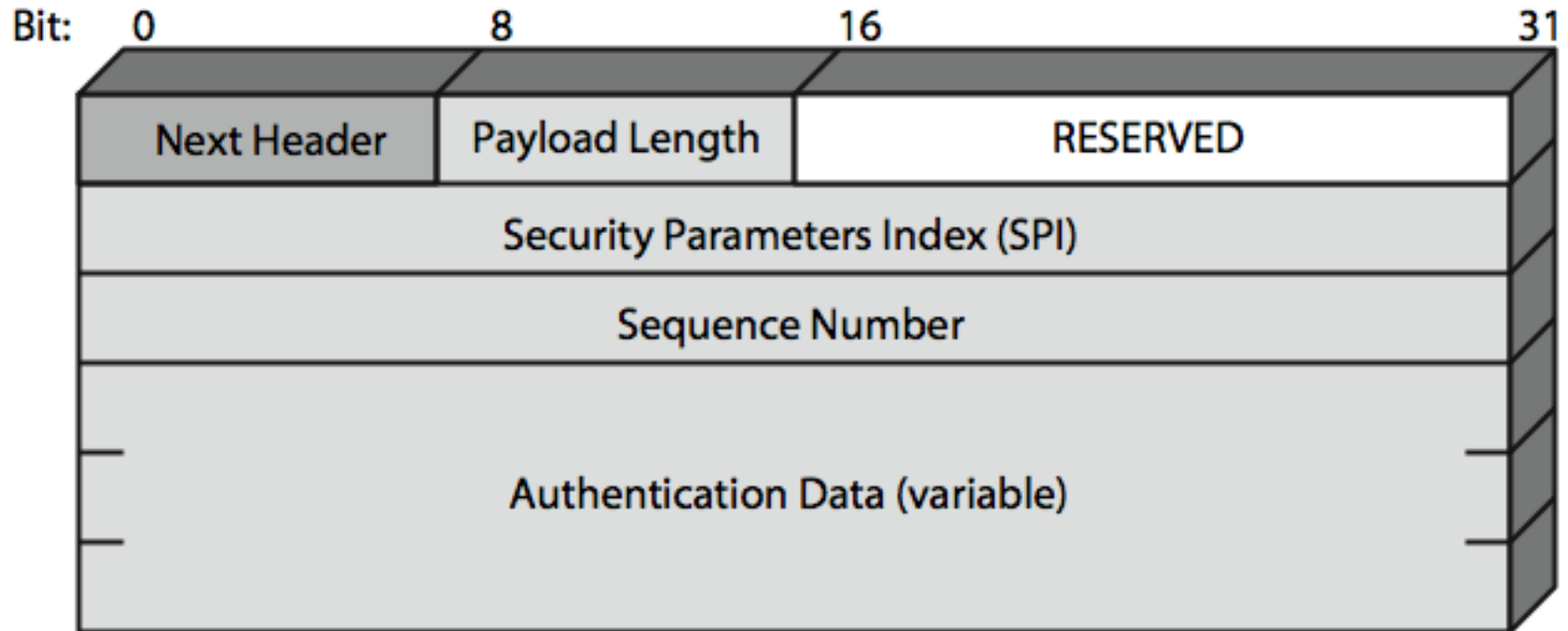
Security Associations

- a one-way relationship between sender & receiver that affords security for traffic flow
- defined by 3 parameters:
 - Security Parameters Index (SPI)
 - IP Destination Address
 - Security Protocol Identifier
- has a number of other parameters
 - seq no, AH & EH info, lifetime etc
- have a database of Security Associations

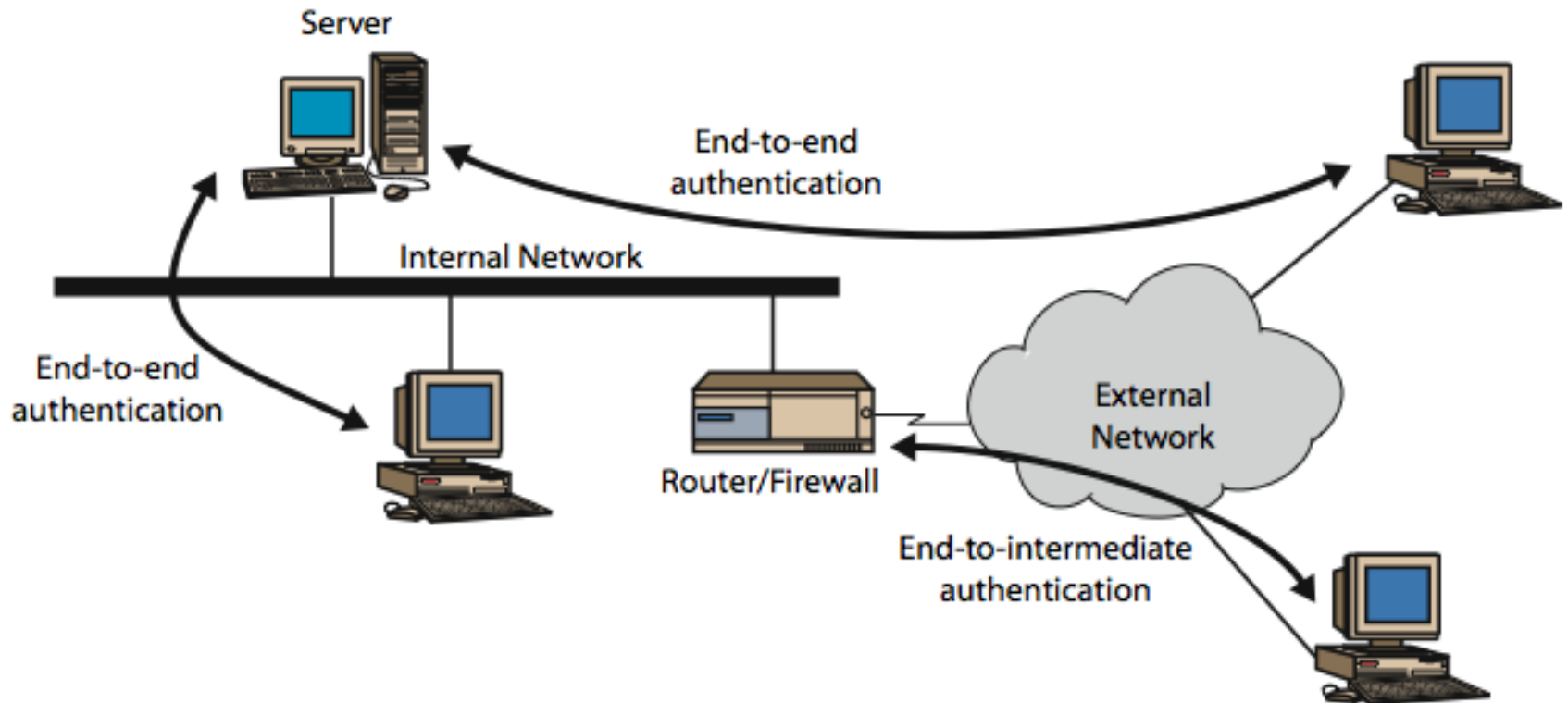
Authentication Header (AH)

- provides support for data integrity & authentication of IP packets
 - end system/router can authenticate user/app
 - prevents address spoofing attacks by tracking sequence numbers
- based on use of a MAC
 - HMAC-MD5-96 or HMAC-SHA-1-96
- parties must share a secret key

Authentication Header



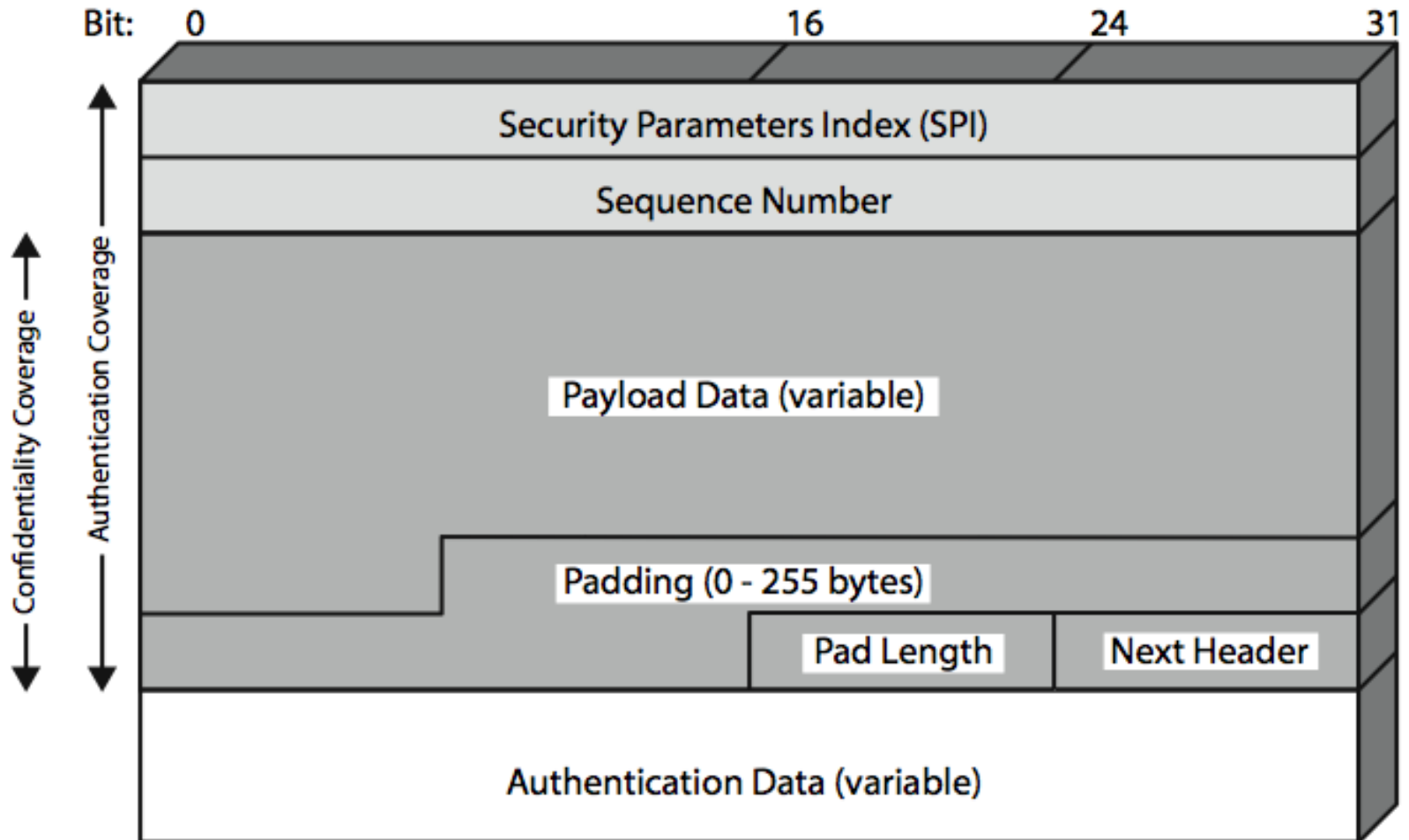
Transport & Tunnel Modes



Encapsulating Security Payload (ESP)

- **provides message content confidentiality & limited traffic flow confidentiality**
- **can optionally provide the same authentication services as AH**
- **supports range of ciphers, modes, padding**
 - **incl. DES, Triple-DES, RC5, IDEA, CAST etc**
 - **CBC & other modes**
 - **padding needed to fill blocksize, fields, for traffic flow**

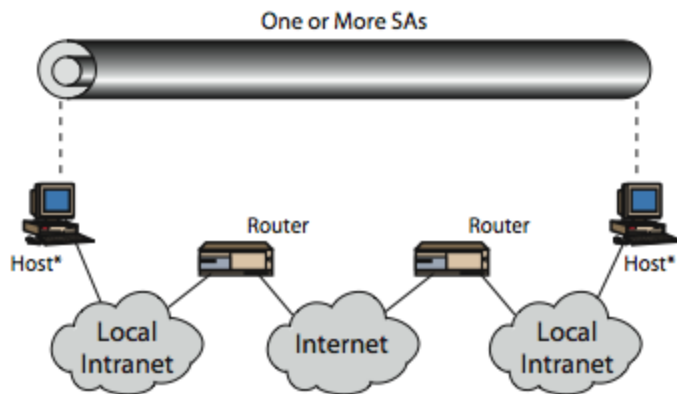
Encapsulating Security Payload



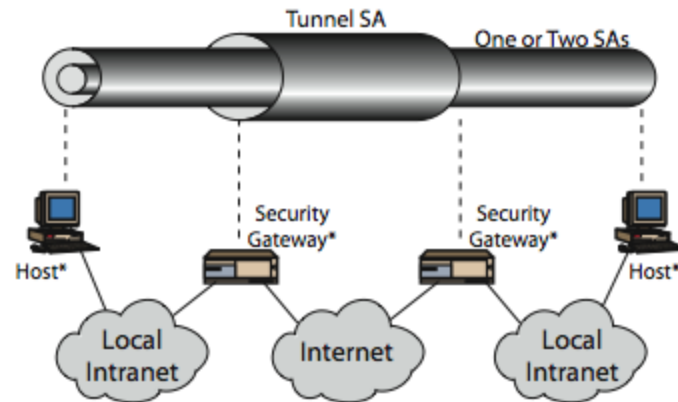
Transport vs Tunnel Mode ESP

- **transport mode is used to encrypt & optionally authenticate IP data**
 - data protected but header left in clear
 - can do traffic analysis but is efficient
 - good for ESP host to host traffic
- **tunnel mode encrypts entire IP packet**
 - add new header for next hop
 - good for VPNs, gateway to gateway security

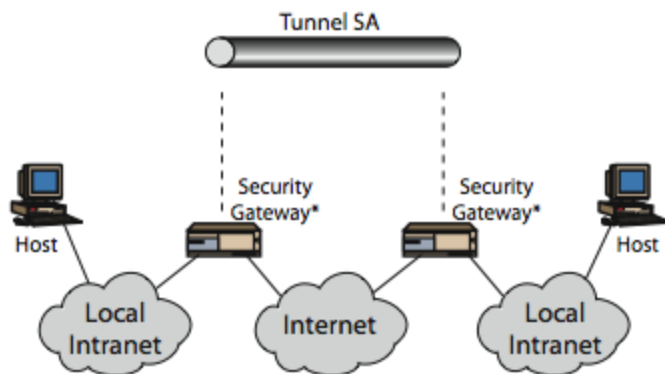
Combining Security Associations



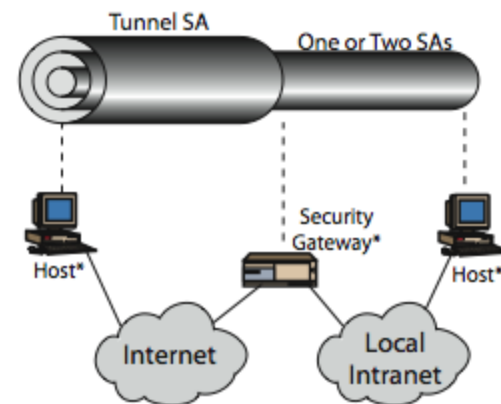
(a) Case 1



(c) Case 3



(b) Case 2



(d) Case 4